CYBERSECURITY AVANZATA · LEZIONE 4 DI 8

TLS e certificati

Che cosa succede nei primi millisecondi di ogni connessione HTTPS, chi garantisce che stai parlando con il sito giusto, e che cosa succede quando quel garante viene violato.

5G TPSI Handshake TLS 1.3, ECDHE, X.509, catena di fiducia, Certificate Transparency

PER COMINCIARE

Il lucchetto nella barra dell'indirizzo ti dice che...

SONDAGGIO

- **A** Il sito è sicuro e affidabile
- **B** Nessuno può leggere ciò che invii a quel sito
- **C** Il sito è di chi dice di essere
- **D** Non l'ho mai guardato

TRE GARANZIE

Che cosa aggiunge TLS a HTTP

Riservatezza

Chi intercetta vede byte cifrati. Cifratura **simmetrica** veloce (AES-GCM, ChaCha20).

Integrità

Ogni pacchetto modificato viene scartato. Cifratura **autenticata**.

Autenticazione

Il server dimostra di essere quel dominio con un **certificato** e la sua chiave privata.

Il problema da risolvere: due computer che non si sono mai visti devono accordarsi su una chiave segreta, **su una rete dove tutti ascoltano**.

TLS 1.3

L'handshake in un solo viaggio di andata e ritorno

ClientHello

Versioni, algoritmi, nome del sito (SNI) e la sua metà dello scambio di chiavi.

ServerHello

Sceglie gli algoritmi e manda la sua metà: ora entrambi calcolano la chiave.

Certificato

Già cifrato: il certificato e la firma con la chiave privata.

Finished

Si verifica che nessuno abbia toccato l'handshake. Parte HTTP.

Asimmetrica per accordarsi e per firmare, **simmetrica** per tutto il resto: è molto più veloce.

TLS 1.2 richiedeva due viaggi prima di inviare dati: TLS 1.3 ne richiede uno.

PUZZLE

Metti in ordine: apri https://scuola.example

1. Il server risponde con ServerHello, certificato e firma
2. Il browser verifica la catena del certificato e il nome
3. Parte la richiesta GET, cifrata con la chiave simmetrica
4. Il DNS risolve il nome in un indirizzo IP
5. Si apre la connessione TCP sulla porta 443
6. Il browser invia il ClientHello con la sua chiave effimera

IL 1976

Un segreto comune, gridato in piazza

> **Oggi siamo alle soglie di una rivoluzione nella crittografia.**
>
> **Whitfield Diffie e Martin Hellman**, prima frase di "New Directions in Cryptography", 1976

Avevano ragione: senza lo scambio di chiavi di Diffie-Hellman non ci sarebbero il commercio elettronico, le chat cifrate e HTTPS ovunque.

QUIZ A TRABOCCHETTO

Nel 2030 viene rubata la chiave privata del certificato di un sito. Chi aveva registrato nel 2026 il traffico TLS 1.3 verso quel sito...

QUIZ

A ora può decifrarlo tutto

B può decifrare solo le password

C non può decifrarlo: le chiavi di sessione erano effimere

D può decifrarlo, se il certificato non era scaduto

AL COMPUTER · 15 minuti

Leggi un certificato vero

1. Apri un sito che usi (per esempio wikipedia.org). Clic sull'icona a sinistra dell'indirizzo, poi **La connessione è sicura**, poi **Il certificato è valido**.
2. Annota in **tls-cognome.md**: a chi è rilasciato, da chi, la validità e i nomi nel campo **Subject Alternative Name**.
3. Nella scheda dei dettagli guarda la **gerarchia**: quanti certificati ci sono dalla radice al sito?
4. DevTools, scheda **Security**: annota versione di TLS e algoritmo di scambio delle chiavi.

Controllo: la catena ha di solito 3 livelli (radice, intermedio, sito); la connessione usa **TLS 1.3**; la validità è di pochi mesi, non di anni.

LA CATENA DI FIDUCIA

Chi garantisce il garante?

Livello	Che cos'è
CA radice	Preinstallata nel sistema e nel browser, chiave tenuta offline
CA intermedia	Firmata dalla radice, firma ogni giorno i certificati dei siti
Sito	Dominio, chiave pubblica, scadenza, firma dell'intermedia

- Il browser risale le firme fino a una radice che conosce
- Poi controlla nome, date ed eventuale revoca
- Basta una sola CA compromessa per falsificare il certificato di **qualsiasi** sito
- Per questo le CA sono controllate da audit e da regole comuni (CA/Browser Forum)

UNA STORIA DEL 2011

DigiNotar: la CA che ha firmato un falso Google

Estate 2011. Un attaccante entra nei sistemi di DigiNotar, CA olandese, e si fa rilasciare centinaia di certificati falsi, tra cui uno per ***.google.com**.

Il certificato è usato per intercettare le connessioni Gmail di centinaia di migliaia di utenti, soprattutto in Iran.

Com'è finita

Chrome se ne accorge perché conosceva in anticipo i certificati attesi per Google. I browser rimuovono DigiNotar dalle radici fidate. A settembre 2011 DigiNotar fallisce.

AL COMPUTER · 15 minuti

Certificate Transparency: tutti i certificati sono pubblici

1. Apri **crt.sh** e cerca il dominio della scuola o di un sito a scelta.
2. Guarda le colonne: data, nome comune, emittente. Quante CA diverse hanno rilasciato certificati per quel dominio nell'ultimo anno?
3. Cerca i **sottodomini** che compaiono: ne trovi qualcuno che non conoscevi?
4. Annota in **tls-cognome.md** perché un'azienda dovrebbe sorvegliare questi log.

Controllo: per un sito attivo trovi decine di certificati, rinnovati ogni pochi mesi. Ogni certificato pubblico emesso oggi è in questi log.

QUIZ

Perché i certificati dei siti durano sempre meno (da anni a pochi mesi)?

QUIZ

A Perché le CA guadagnano di più con i rinnovi

B Perché un certificato rubato o sbagliato resta utilizzabile per meno tempo e il rinnovo diventa automatico

C Perché la crittografia si consuma con l'uso

D Perché lo impone il GDPR

AL COMPUTER · 25 minuti

La catena in Java

```
var c = (HttpsURLConnection) URI
    .create("https://www.wikipedia.org").toURL()
    .openConnection();
c.connect();
for (Certificate cert : c.getServerCertificates()) {
  X509Certificate x = (X509Certificate) cert;
  System.out.println(x.getSubjectX500Principal());
  System.out.println("  firmato da " + x.getIssuerX500Principal());
  System.out.println("  scade il " + x.getNotAfter());
}
```

Scrivi **Catena.java**, provalo su tre siti, poi stampa anche `c.getCipherSuite()`.

Controllo: il primo certificato stampato è quello del sito (CN con il dominio), i successivi sono gli intermedi; ognuno è "firmato da" il successivo. La cipher suite è del tipo **TLS_AES_128_GCM_SHA256**.

PUZZLE

Abbina ogni campo del certificato al suo scopo

Subject Alternative Name	---	La firma della CA su tutti gli altri campi
Issuer	---	La data di scadenza
Not After	---	La chiave che verifica le firme del server
Public Key	---	I nomi di dominio per cui il certificato vale
Signature	---	La CA che ha firmato il certificato

AL COMPUTER · 30 minuti

Un certificato fatto in casa

```
keytool -genkeypair -alias lab -keyalg EC -validity 30
  -dname "CN=localhost" -ext SAN=dns:localhost
  -keystore lab.p12 -storetype PKCS12 -storepass laboratorio
```

1. Crea il certificato con il comando (tutto su una riga).
2. Avvia un `HttpsServer` sulla porta 8443 con quel keystore: risponde "ciao TLS".
3. Apri **https://localhost:8443** nel browser e poi con `curl -k`.

Controllo: il browser avvisa che **la connessione non è privata** (autorità non riconosciuta). curl senza `-k` rifiuta, con `-k` stampa "ciao TLS". La cifratura c'è: manca la **fiducia**.

OGGI

TLS si prepara ai computer quantistici

Un computer quantistico abbastanza grande romperebbe RSA e le curve ellittiche. Chi registra oggi il traffico cifrato potrebbe decifrarlo domani: **"raccogli ora, decifra dopo"**.

La cifratura simmetrica (AES) e gli hash reggono con chiavi lunghe.



OGGI

Certificati a vita breve, rinnovati dalle macchine

- Durata massima dei certificati pubblici in calo graduale fino a **47 giorni** entro il 2029
- Rinnovo automatico con **ACME**: il server chiede, dimostra di controllare il dominio, installa
- Un certificato scaduto è tra le cause più comuni di disservizi



SFIDA A SQUADRE

Apri il lucchetto



- 1ª e 2ª cifra: la versione di TLS che ha eliminato lo scambio di chiavi RSA, senza punto
- 3ª e 4ª cifra: la durata massima in giorni prevista per i certificati entro il 2029

codice

BIGLIETTO D'USCITA

Completa prima di uscire

Lo scambio di chiavi effimero di TLS 1.3 si chiama _____.

Rubare la chiave domani non apre il traffico di ieri: è la forward _____.

Il campo con i nomi di dominio di un certificato è il Subject Alternative _____.

Il registro pubblico di tutti i certificati emessi è la Certificate _____.

La CA olandese fallita nel 2011 si chiamava _____.

⏱ 3:00

RIEPILOGO

Cosa portiamo a casa

- TLS: riservatezza, integrità, autenticazione del server
- TLS 1.3: un viaggio, ECDHE, forward secrecy
- Catena: radice, intermedia, sito
- Autofirmato: cifra, ma non dà fiducia
- DigiNotar: una CA caduta, la fiducia di tutti in pericolo
- Certificate Transparency: ogni certificato è pubblico
- Certificati brevi e ACME; scambio ibrido post-quantistico
- Prossima lezione: OAuth, JWT e passkey

Hai una domanda su una slide? Usa il pulsante **? Domande** in basso: la vedrà il docente e tutta la classe.